



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2024-21182 Oracle WebLogic Server Unspecified Vulnerability

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-01
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2024-21182 Oracle WebLogic Server Unspecified Vulnerability - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-01 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2024-21182 Oracle WebLogic Server Unspecified Vulnerability

1. Executive Summary

CVE-2024-21182 is a high-severity Oracle WebLogic Server vulnerability that CISA added to the Known Exploited Vulnerabilities (KEV) catalog on 2026-06-01, confirming exploitation in the wild. Oracle and NVD describe the issue as an easily exploitable, unauthenticated network vulnerability in the WebLogic Server Core component that is reachable over the T3 and IIOP protocols. Successful exploitation can expose critical data or all data accessible to the compromised WebLogic instance.

The immediate defensive problem is exposure, not just score. Oracle rates the flaw at CVSS v3.1 7.5 because the public description emphasizes confidentiality impact, but the vulnerable path is remotely reachable without authentication and CISA has already elevated it into KEV. For defenders, any externally reachable or broadly internally reachable WebLogic deployment on affected versions should be treated as an urgent remediation and retrospective-hunting priority.

Secondary public reporting and a public lab repository indicate that security researchers have connected this flaw to the broader WebLogic JNDI-injection / OpaqueReference vulnerability family. Even where defenders do not rely on those exploitation specifics, the primary-source picture is already sufficient: the issue is active, remotely reachable, and should be handled on an emergency basis wherever T3 or IIOP exposure exists.

Confirmed facts:

- CVE ID: CVE-2024-21182
- Vendor: Oracle
- Product: WebLogic Server
- Component: Core
- Affected versions: 12.2.1.4.0 and 14.1.1.0.0
- Reachability: network, unauthenticated, via T3 / IIOP
- CVSS v3.1: 7.5 High
- CVSS vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
- KEV date added: 2026-06-01
- KEV due date for FCEB agencies: 2026-06-04

Analyst assessment:

- Prioritize any internet-facing or partner-reachable WebLogic estate immediately.
- Assume opportunistic scanning and exploit attempts are plausible now that the flaw is in KEV and public exploit-lab material exists.
- If patching cannot be completed at once, reduce exposure to T3 and IIOP while compromise assessment proceeds in parallel.

2. Vulnerability Metadata

Field	Value
CNA / vendor	Oracle
NVD published date	2024-07-16
NVD last modified at review time	2026-06-01
Vendor advisory family	Oracle Critical Patch Update Advisory - July 2024
Product family	Oracle Fusion Middleware
Product	Oracle WebLogic Server
Component	Core

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality / Integrity / Availability impact	High / None / None
CWE mapping in NVD	NVD-CWE-noinfo

Key metadata: Affected products called out in primary sources:

Operational implications:

- Oracle WebLogic Server 12.2.1.4.0
- Oracle WebLogic Server 14.1.1.0.0
- The vulnerable path is reachable over T3 and IIOP rather than ordinary browser-only workflows.
- Exposure can matter both on internet-facing middleware and on internally reachable application tiers.
- CISA KEV inclusion turns this into a remediation-priority issue even without a public vendor deep dive on root cause.

3. Source Review & Confidence

Primary-source basis: Secondary-source basis:

Source	Contribution	Confidence
Government advisory / KEV catalog entry	CISA lists CVE-2024-21182 as a known exploited vulnerability, added on 2026-06-01 with a due date of 2026-06-04. The ent	High-confidence primary source for exploitation status and urgency.
Vendor advisory	Oracle's July 2024 CPU lists CVE-2024-21182 in Oracle WebLogic Server Core, reachable over T3 and IIOP, with CVSS 7.5 an	High-confidence primary source for vendor-scoped affected versions, protocol reachability, and sever
Government vulnerability database API	NVD publishes the normalized CVE description, CVSS v3.1 vector, affected CPEs for WebLogic 12.2.1.4.0 and 14.1.1.0.0, an	High-confidence primary source for normalized scoring and machine-readable affected-product detail.
CVE Program API	The CVE Program record confirms Oracle WebLogic Server as the affected product and lists versions 12.2.1.4.0 and 14.1.1.	High-confidence primary source for canonical CVE record data.
Secondary reporting	Public reporting framed the KEV addition as evidence of active exploitation and highlighted urgency for patching exposed	Secondary source used for threat-landscape context, not for canonical vulnerability facts.
Secondary database summary	GitHub Advisory Database restates the Oracle/NVD description and severity context for the vulnerability.	Secondary source used as an accessible corroborating summary.
Public research / proof-of-concept lab	A public lab repository describes the issue	Treat as unverified secondary technical

documentation	as part of the WebLogic JNDI-injection / OpaqueReference family and presents	context for exploitability framing only.
---------------	--	--

Confidence assessment:

4. Vulnerability Details

Oracle and NVD describe CVE-2024-21182 as an easily exploitable vulnerability in the Core component of Oracle WebLogic Server. The documented attack path requires no authentication and is reachable over the T3 and IIOP protocols. Successful exploitation can lead to unauthorized access to critical data or to all data accessible by the WebLogic Server instance.

From a defender's perspective, two aspects matter most:

- the weakness is reachable over network services that are often exposed to application integrations, administration paths, or east-west middleware traffic;
- the impact statement implies compromise of sensitive application and platform data even though the published CVSS framing emphasizes confidentiality rather than overt service disruption.

A public research lab published after the original July 2024 advisory characterizes the issue as part of a WebLogic JNDI-injection / OpaqueReference exploitation family and presents an unauthenticated remote-code-execution demonstration in a controlled lab. That should be treated as useful secondary context rather than the sole basis for remediation decisions. Defenders do not need a full exploit-chain understanding to act: primary sources already establish affected versions, reachability, and in-the-wild exploitation.

5. Attack Scenarios

Scenario 1: Internet-facing middleware exposure

- An attacker identifies a WebLogic service with reachable T3 or IIOP exposure.
- The attacker targets an affected 12.2.1.4.0 or 14.1.1.0.0 instance without valid credentials.
- Successful exploitation exposes sensitive application or middleware-resident data and may enable broader follow-on intrusion depending on deployment context.

Scenario 2: Internal foothold followed by middleware exploitation

- An attacker gains access to a workstation, VPN session, or adjacent server.
- The attacker enumerates internal Oracle middleware services and reaches WebLogic over T3 or IIOP.
- Exploitation of a vulnerable internal application tier becomes a pivot toward business applications, data stores, and identity-linked services.

Scenario 3: Opportunistic exploitation after KEV listing

- Threat actors or scanners use the KEV listing and public exploit-lab material to prioritize Oracle WebLogic targets.
- Defenders may first detect suspicious traffic, process activity, or follow-on data access on systems that had not been considered directly internet-exposed.

6. Threat Landscape & Exploitation Status

CISA added CVE-2024-21182 to KEV on 2026-06-01 with a remediation due date of 2026-06-04 for Federal Civilian Executive Branch agencies. That is the strongest public signal in the reviewed source set that the flaw is being exploited in the wild and should be prioritized beyond normal patch cycles.

The Hacker News and other public reporting around the KEV addition emphasize that Oracle originally addressed the vulnerability in the July 2024 Critical Patch Update, yet exploitation activity still surfaced later. That gap matters operationally because it suggests some organizations may have left WebLogic exposure unremediated for an extended period.

CISA's KEV entry lists `knownRansomwareCampaignUse` as `Unknown`, so this review does not attribute the flaw to a specific ransomware operation. Even so, active exploitation of unauthenticated middleware vulnerabilities should be treated as a high-likelihood precursor to credential abuse, sensitive-data access, web-tier persistence, and application-environment pivoting.

7. Affected Products and Exposure

Affected products:

- Oracle WebLogic Server 12.2.1.4.0
- Oracle WebLogic Server 14.1.1.0.0

Highest-priority exposure classes:

- Internet-facing Oracle WebLogic services
- WebLogic clusters reachable from partner networks, DMZ segments, or broad VPN address pools
- Internal middleware tiers reachable over east-west traffic where T3 or IIOP is not tightly restricted
- Legacy enterprise application estates where WebLogic ownership is fragmented across multiple teams

Immediate scoping questions:

- Which WebLogic assets are running 12.2.1.4.0 or 14.1.1.0.0?
- Which systems expose T3 or IIOP externally or to broad internal network segments?
- Which application owners depend on those systems and may delay emergency maintenance?
- Which hosts lack complete logging for middleware, host process activity, and network connections?

Useful local pivots:

- CMDB or asset inventory entries for Oracle Fusion Middleware / WebLogic
- Network scans or load-balancer inventories showing T3 or IIOP reachability
- Oracle patch records tied to the July 2024 CPU and later maintenance windows
- EDR, firewall, and proxy telemetry from WebLogic hosts and adjacent application tiers

8. Mitigation and Workarounds

Immediate actions:

- Apply Oracle's security updates and mitigations for CVE-2024-21182 as directed in the July 2024 Critical Patch Update guidance and any newer cumulative maintenance applicable to the deployment.
- Identify every WebLogic Server 12.2.1.4.0 and 14.1.1.0.0 instance in production, staging, and DR environments.
- Restrict or disable unnecessary T3 and IIOP exposure wherever operationally possible while patching is in progress.
- Preserve application, host, and network telemetry before cleanup if compromise is suspected.

Short-term hardening:

- Limit management and middleware protocol access to tightly controlled administrative or application source ranges.
- Review segmentation around WebLogic clusters, admin servers, and dependent database/application tiers.
- Confirm WebLogic logs, host logs, and EDR telemetry are centrally retained and searchable.
- Review service accounts, deployment credentials, and privileged integrations associated with impacted middleware.

Workaround note:

- The authoritative remediation path is vendor-directed patching and mitigation.
- Network exposure reduction is a useful emergency control, but it should not be treated as complete remediation for an actively exploited unauthenticated vulnerability.

9. Detection Engineering

Detection priorities: Recommended telemetry: Practical analytic themes: Because reviewed sources do not provide stable exploitation strings or authoritative network signatures, defenders should anchor detections to exposure, protocol use, post-exploitation behavior, and anomalous middleware host activity rather than a single brittle indicator.

Signal	Telemetry Source	Analytic Goal
--------	------------------	---------------

New or unusual inbound connections to WebLogic hosts over T3, IIOP, or adjacent middleware-management ports	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Process execution, Java child-process behavior, or shell spawns from WebLogic service accounts	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Unexpected outbound connections from WebLogic hosts after suspicious inbound traffic	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Access to application data stores or sensitive middleware-resident data shortly after suspicious network activity	Network, auth, proxy, or service-access logs	Identify externally reachable or suspiciously accessed systems
Firewall, load-balancer, and network sensor telemetry covering WebLogic listener exposure	Network, auth, proxy, or service-access logs	Identify externally reachable or suspiciously accessed systems

9.1 Detection Query

```
// Internet-facing service inventory and version-discovery pivots for CVE-2024-21182 Oracle WebLogic
Server Unspecified Vulnerability
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("weblogic", "panos", "litlelm", "docker ps", "kubectl get pods")
| project Timestamp, DeviceName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// External exposure and suspicious follow-on activity
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443)
| project Timestamp, DeviceName, InitiatingProcessFileName, LocalIP, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

10. Threat Hunting

Hunt objectives:

- Identify every vulnerable WebLogic instance and correlate it with protocol exposure.
- Review historical telemetry for suspicious T3 or IIOP access to affected hosts.
- Find signs of post-exploitation activity such as unusual child processes, outbound callbacks, or data-access anomalies.
- Determine whether any vulnerable WebLogic host was used as a pivot into adjacent application or database tiers.

Suggested hunt questions:

- Which source IPs connected to WebLogic over T3 or IIOP during the period surrounding KEV listing and earlier patch windows?
- Did affected hosts show new outbound traffic patterns, especially to infrastructure not normally contacted by middleware nodes?
- Were there unexpected shell, scripting, or deployment-tool executions under WebLogic service identities?
- Did downstream application, database, or IAM systems record unusual access that followed suspicious middleware traffic?

Useful local pivots:

- Network-flow and firewall records keyed on WebLogic listener ports and hostnames
- EDR timelines for Java, shell, Python, Perl, or other interpreter execution on WebLogic nodes
- WebLogic server logs and authentication / configuration change records
- Database and application audit trails associated with the applications hosted on affected middleware

10.1 Hunt Query

```
// External exposure and suspicious follow-on activity
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443)
| project Timestamp, DeviceName, InitiatingProcessFileName, LocalIP, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

11. MITRE ATT&CK Mapping

Mapped ATT&CK techniques:

- T1190 - Exploit Public-Facing Application
- Rationale: Internet-exposed WebLogic services are the highest-priority initial-access scenario for this KEV-listed vulnerability.
- T1210 - Exploitation of Remote Services
- Rationale: The vulnerability is reachable over network middleware protocols and may also be exploited across internal trust boundaries after an initial foothold.

Interpretation:

- T1190 captures the urgent public-exposure problem.
- T1210 captures realistic east-west exploitation risk in enterprise environments where WebLogic is not internet-facing but remains broadly reachable.

12. Validation / Lab Testing

Safe validation steps:

- Inventory WebLogic versions on all known Oracle middleware assets and verify whether any remain at 12.2.1.4.0 or 14.1.1.0.0 without the relevant security update path applied.
- Confirm whether T3 and IIOP are reachable from the internet, partner segments, or broad internal ranges.
- Validate that host and network telemetry exists for WebLogic nodes before attempting emergency isolation or rebuild actions.
- Review a lab or staging environment to verify patch level, protocol exposure, and logging coverage.

Recommended validation checklist:

1. Build a complete list of WebLogic Server 12.2.1.4.0 and 14.1.1.0.0 systems.
2. Confirm which of those systems expose T3 or IIOP externally or internally.
3. Verify that Oracle CPU July 2024 remediation or later vendor-approved security maintenance has been applied.
4. Review host and network telemetry for suspicious access dating back to the original 2024 advisory, with special focus on the period before and after KEV addition on 2026-06-01.
5. Confirm segmentation and emergency access controls for any system that cannot be patched immediately.
6. Conduct compromise assessment on high-value or exposed WebLogic nodes before closing the response window.

Do not test exploit code against production WebLogic systems.

13. Recommended Actions Summary

Critical - Application / Middleware Owners - 24 hours Critical - SOC / IR - 24 hours High - Network / Security Engineering - 24 to 48 hours High - Asset / Platform Management - 48 hours

Priority	Owner	Action
Critical	Platform / Application Owners	Patch or otherwise remediate every affected WebLogic 12.2.1.4.0 and 14.1.1.0.0 deployment per Oracle guidance.
High	Security / Platform Owners	Identify and reduce T3 / IIOP exposure on any system that cannot be remediated immediately.
High	SOC / Detection Engineering	Hunt historical telemetry for suspicious T3 / IIOP connections, unusual outbound activity, and process execution on WebLogic hosts.
High	SOC / Detection Engineering	Prioritize compromise assessment on internet-facing or partner-reachable WebLogic environments.
High	SOC / Detection Engineering	Tighten ACLs and segmentation around WebLogic listener exposure.
High	SOC / Detection Engineering	Confirm retention and alerting coverage for middleware host telemetry, network flows, and downstream application access.

14. References

7. CISA Known Exploited Vulnerabilities Catalog - CVE-2024-21182
8. Oracle Critical Patch Update Advisory - July 2024
9. CVE Program record - CVE-2024-21182
10. NVD entry - CVE-2024-21182
11. The Hacker News - Oracle WebLogic CVE-2024-21182 Added to KEV Catalog After Active Exploitation
12. GitHub Advisory Database - GHSA-rr6f-mqf5-f7wc
13. Public lab documentation - CVE-2024-21182